현재 코드(Git 7e45c93)를 바탕으로 재구성한 비교용 초안이며, 코드 구성·수정 및 테스트는 AI가 수행했습니다. 본인 직접 수행 여부는 확인 필요입니다.

AI 초안 수정 및 검증 기록

2026-10-19 · 경동대학교 동아리 웹사이트

학번: _____ 이름: _____

1. 비교 대상과 실행 방법

ai_draft/는 이름 검색·PDF 첨부·개별 알림 읽음을 중심으로 범위를 축소한 코드입니다. final_code/는 현재 실행 코드 사본입니다. 계정 권한, SQL 매개변수 바인딩, 파일 용량 제한, 알림 중복·수신자 검사는 초안에도 유지했습니다.

각 폴더에서 `python app.py`로 실행합니다. Python 3.10 이상(3.12 권장)과 최초 의존성 설치 시 인터넷 연결이 필요합니다. 학생: kdu_student / sample1234, 교수: kdu_professor / sample1234.

이번 자료는 기존 프로젝트와 분리된 사본입니다. 로그인·가입·개설 심사·데이터 저장 등 나머지 기능은 현재 코드 구조를 사용합니다. 수정은 아래 세 함수의 차이로 한정합니다.

2. 수정 내역 요약

번호 / 함수	초안 → 최종	수정 이유	관련 점검
1. index	이름만 검색 → 이름·소개·캠퍼스 검색	이름만 검색하는 범위를 소개와 캠퍼스까지 확대했습니다. 입력값은 계속 ? 매개변수로 전달하여 따옴표를 SQL 문법으로 처리하지 않습니다.	7장 검색·필터
2. validated_upload	PDF만 첨부 → 5개 형식 및 내용 검사	PDF만 받는 범위를 PDF/HWP/DOCX/JPG/PNG로 확대하고 이미지·문서 형식 검사를 추가했습니다. 10MiB 용량 제한과 금지 확장자 거부는 두 버전 모두	7장 파일 업로드

		유지합니다.	
3. read_all_notifications	개별 읽음 안내 → 본인 알림 일괄 읽음	개별 읽음만 안내하던 처리를 현재 로그인한 사용자의 알림만 일괄 갱신하도록 바꿨습니다. 중복 알림 방지 및 수신자 제한은 기존 기능이며 별도로 검증합니다.	7장 알림 관련 추가 점검

3-1. 검색 범위 확대

app.py / index(): 초안 312행, 최종 312행

이름만 검색하는 범위를 소개와 캠퍼스까지 확대했습니다. 입력값은 계속 ? 매개변수로 전달하여 따옴표를 SQL 문법으로 처리하지 않습니다.

수정 전 코드

```
def index():
    keyword = request.args.get('keyword', '').strip()
    category = request.args.get('category', 'all')
    query = "SELECT * FROM clubs WHERE status='approved'"
    params = []
    if keyword:
        query += ' AND name LIKE ?'
        params.append(f'%{keyword}%')
    if category != 'all':
        aliases={'예술':['예술','공연'],'사회·봉사':['사회·봉사','봉사']}
        selected=aliases.get(category,[category])
        query += ' AND category IN ('+','.join('?' for _ in selected)+')'
        params.extend(selected)
    clubs = [club_view(c) for c in rows(query + ' ORDER BY id', params)]
    recruiting_only = request.args.get('recruiting') == '1'
    if recruiting_only:
        clubs = [c for c in clubs if c['recruitment']['open']]
    favorites = {r['club_id'] for r in rows('SELECT club_id FROM club_favorites WHERE user_id=?',
(session.get('user_id', 0),))}
    return render_template('index.html', clubs=clubs, keyword=keyword, category=category,
                           recruiting_only=recruiting_only, favorite_club_ids=favorites)
```

수정 후 코드

```
def index():
    keyword = request.args.get('keyword', '').strip()
    category = request.args.get('category', 'all')
    query = "SELECT * FROM clubs WHERE status='approved'"
    params = []
    if keyword:
        query += ' AND (name LIKE ? OR description LIKE ? OR campus LIKE ?)'
        params.extend([f'%{keyword}%'] * 3)
    if category != 'all':
        aliases={'예술':['예술','공연'],'사회·봉사':['사회·봉사','봉사']}
        selected=aliases.get(category,[category])
        query += ' AND category IN ('+','.join('?' for _ in selected)+')'
        params.extend(selected)
    clubs = [club_view(c) for c in rows(query + ' ORDER BY id', params)]
    recruiting_only = request.args.get('recruiting') == '1'
    if recruiting_only:
        clubs = [c for c in clubs if c['recruitment']['open']]
    favorites = {r['club_id'] for r in rows('SELECT club_id FROM club_favorites WHERE user_id=?',
(session.get('user_id', 0),))}
    return render_template('index.html', clubs=clubs, keyword=keyword, category=category,
                           recruiting_only=recruiting_only, favorite_club_ids=favorites)
```

직접 적용 방법: ai_draft/app.py에서 해당 함수의 본문을 위 수정 후 코드로 교체합니다. 함수 위의 @app 경로 선언은 유지합니다. 세 함수 모두 반영한 뒤 같은 테스트를 다시 실행합니다.

3-2. 첨부 형식 확대

app.py / validated_upload(): 초안 748행, 최종 749행

PDF만 받는 범위를 PDF/HWP/DOCX/JPG/PNG로 확대하고 이미지·문서 형식 검사를 추가했습니다. 10MiB 용량 제한과 금지 확장자 거부는 두 버전 모두 유지합니다.

수정 전 코드

```
def validated_upload(file):
    """PDF 첨부의 용량과 헤더를 확인합니다."""
    data = file.read(10 * 1024 * 1024 + 1)
    if len(data) > 10 * 1024 * 1024:
        raise ValueError('파일은 각각 10MB 이하여야 합니다.')
    ext = Path(file.filename or '').suffix.lower()
    if ext != '.pdf' or not data.startswith(b'%PDF-'):
        raise ValueError('PDF 파일만 첨부할 수 있습니다.')
    return data, ext
```

수정 후 코드

```
def validated_upload(file):
    """용량·실제 형식을 검사합니다. 파일 이름은 표시용으로만 사용합니다."""
    data=file.read(10*1024*1024+1)
    if len(data)>10*1024*1024:
        raise ValueError('파일은 각각 10MB 이하여야 합니다. 작성 내용은 유지됩니다.')
    if not data:
        raise ValueError('빈 파일은 첨부할 수 없습니다.')
    ext=Path(file.filename or '').suffix.lower()
    if ext in {'.jpg','.jpeg','.png'}:
        try:
            with Image.open(io.BytesIO(data)) as image:
                if image.format not in ({'PNG'} if ext=='.png' else {'JPEG'}):
                    raise ValueError()
                image.verify()
        except (UnidentifiedImageError,OSError,ValueError,Image.DecompressionBombError):
            raise ValueError('이미지 내용과 확장자가 일치하지 않거나 이미지가 손상되었습니다.')
    elif ext=='.pdf':
        if not data.startswith(b'%PDF-'):
            raise ValueError('PDF 형식을 확인해주세요.')
    elif ext=='.hwp':
        if not data.startswith(b'\xd0\xcf\x11\xe0\xa1\xb1\x1a\xe1'):
            raise ValueError('HWP 형식을 확인해주세요.')
    elif ext=='.docx':
        try:
            with zipfile.ZipFile(io.BytesIO(data)) as archive:
                if 'word/document.xml' not in archive.namelist() or sum(f.file_size for f in
archive.infolist())>100*1024*1024:
                    raise ValueError()
        except (zipfile.BadZipFile,ValueError):
            raise ValueError('DOCX 형식을 확인해주세요.')
    else:
        raise ValueError('PDF, HWP, DOCX, JPG, PNG 파일만 첨부할 수 있습니다.')
    return data,ext
```

직접 적용 방법: ai_draft/app.py에서 해당 함수의 본문을 위 수정 후 코드로 교체합니다. 함수 위의 @app 경로 선언은 유지합니다. 세 함수 모두 반영한 뒤 같은 테스트를 다시 실행합니다.

3-3. 알림 일괄 읽음 처리

app.py / read_all_notifications(): 초안 569행, 최종 569행

개별 읽음만 안내하던 처리를 현재 로그인한 사용자의 알림만 일괄 갱신하도록 바꿨습니다. 중복 알림 방지 및 수신자 제한은 기존 기능이며 별도로 검증합니다.

수정 전 코드

```
def read_all_notifications():
    student_required()
    flash('알림을 하나씩 선택하여 읽음 처리해주세요.', 'info')
    return redirect(url_for('notifications'))
```

수정 후 코드

```
def read_all_notifications():
    student_required()
    get_db().execute('UPDATE notifications SET is_read=1 WHERE user_id=?', (session['user_id'],))
    get_db().commit()
    return redirect(url_for('notifications'))
```

직접 적용 방법: ai_draft/app.py에서 해당 함수의 본문을 위 수정 후 코드로 교체합니다. 함수 위의 @app 경로 선언은 유지합니다. 세 함수 모두 반영한 뒤 같은 테스트를 다시 실행합니다.

4. 7장 체크리스트 점검

외부 API 연동

점검 항목: API 요청 실패 처리와 API 키 노출 여부

외부 API 기능을 선택하지 않아 해당 없음. 학교 SSO·외부 메시지 발송을 구현하지 않았습니다.

파일 업로드

점검 항목: 금지 확장자 또는 지나치게 큰 파일 거부

두 버전 모두 해당 테스트 통과. bad.exe, 손상된 이미지/PDF/DOCX, 10MiB 초과 파일을 거부하고 첨부 DB에 저장하지 않는지 검사합니다. 최종본은 정상 PNG/PDF/HWP/DOCX 허용 테스트도 통과했습니다.

검색·필터

점검 항목: 특수문자·따옴표 입력 시 오류 없이 동작하고 SQL 인젝션 방지

두 버전 모두 해당 테스트 통과. 따옴표 및 SQL 형태 문자열을 입력하여 HTTP 200, 불필요한 결과 없음, 동아리 데이터 유지 여부를 검사합니다. 소개·캠퍼스 검색은 추가 기능 검사로 초안 실패, 최종 통과입니다.

알림

점검 항목: 동일 이벤트 중복 방지 및 잘못된 수신자 방지

두 버전 모두 중복 심사·수신자 검사 통과. 개설/가입 승인 반복 시 알림 중복 여부와 수신자 ID를 확인합니다. 다른 사용자의 알림 접근을 차단하는지도 검사합니다. 일괄 읽음 범위 검사는 초안 실패, 최종 통과입니다.

근거: 제공된 7장 이미지 및 기존 과제 안내문의 해당 항목. 정상 파일 형식 확대·검색 범위 확대·일괄 읽음은 추가 기능 점검이며, 초안에 SQL 인젝션 취약점이나 중복 알림 문제가 있었다는 뜻은 아닙니다.

5. 테스트 방법과 실제 결과

각 사본 폴더에서 같은 50개 테스트를 실행했습니다. Flask 테스트 클라이언트와 임시 SQLite DB를 사용하며, 사용자의 기존 DB는 변경하지 않았습니다.

명령: python -m unittest discover -s tests -v

의존성이 .venv에 설치된 경우 Windows: .\.venv\Scripts\python.exe -m unittest discover -s tests -v

Linux: .venv/bin/python -m unittest discover -s tests -v

대상	실행	통과	실패	오류
비교용 초안	50	45	3	2
최종 코드	50	50	0	0

test_description_and_campus_search

관찰: 소개·캠퍼스 검색 결과가 없음

최종 코드의 대응: index()의 LIKE 검색 범위를 확대

test_valid_file_formats

관찰: 정상 PNG 업로드가 400으로 거부됨

최종 코드의 대응: validated_upload()의 허용 형식과 실제 내용 검사 확대

test_read_all_scoped

관찰: 본인 알림이 읽음으로 바뀌지 않음

최종 코드의 대응: read_all_notifications()에서 user_id 조건으로 UPDATE

test_post_attachment_limit_and_cross_club / test_post_validation_preserves_fields

관찰: PNG 업로드가 거부되어 응답에 id가 없고 테스트에서 KeyError 발생

최종 코드의 대응: 첨부 형식 확대로 정상 PNG 업로드 응답에 id 제공

50개는 기존 기능 42개, 실행 환경 준비 7개, 이번 비교를 위한 소개·캠퍼스 검색 1개입니다. 실패는 최종본의 기능 기대값으로 초안을 검사한 결과입니다. 기존 7장 핵심 보호 기능은 유지되었으며, 기능 축소에 따른 실패와 보호 기능 결함을 구분했습니다.

6. 최종 검증 범위와 제출 전 확인

최종 사본은 위 테스트 50개를 통과했습니다. Windows 실기기 실행·브라우저 수동 조작·실제 사용자 환경은 이번 검증에서 수행하지 않았습니다. 파일 형식 검사는 악성코드 검사를 의미하지 않습니다. 로그에 표시된 ResourceWarning과 손상 PDF 검사 메시지는 원문 그대로 보존했습니다.

본인 수행 기록: 수행 날짜 / 직접 적용한 함수 / 변경 이유를 본인 말로 설명 / 실행 결과 캡처를 직접 수행 후 작성합니다. 현재 결과만으로 학생 본인의 직접 수정 또는 직접 실행을 확인할 수는 없습니다.

첨부: ai_draft.zip, final_code.zip, code_comparison.md, code_changes.diff, evidence/ai_draft_tests.log, evidence/final_code_tests.log. 프로그램 내부 DB와 비밀 설정은 압축에 포함하지 않습니다.